SQL Injection Vulnerability Report – DVWA

Objective

Identify and exploit SQL Injection vulnerability in DVWA to understand improper input validation.

Environment

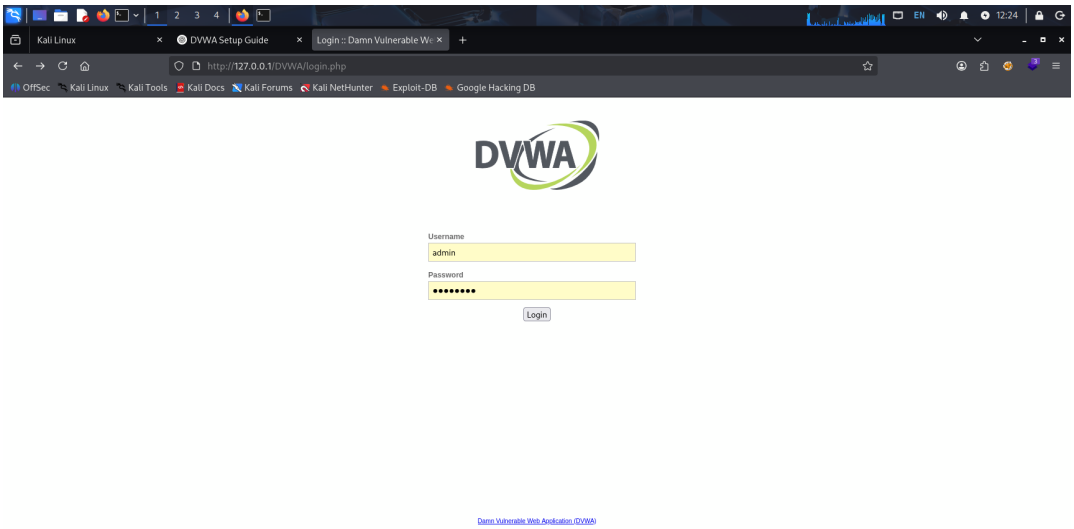
Application: DVWA
Platform: Kali Linux
Database: MariaDB
Security Level: Low

Vulnerability Description

SQL Injection occurs when user input is directly used in SQL queries without sanitization, allowing attackers to manipulate database queries.

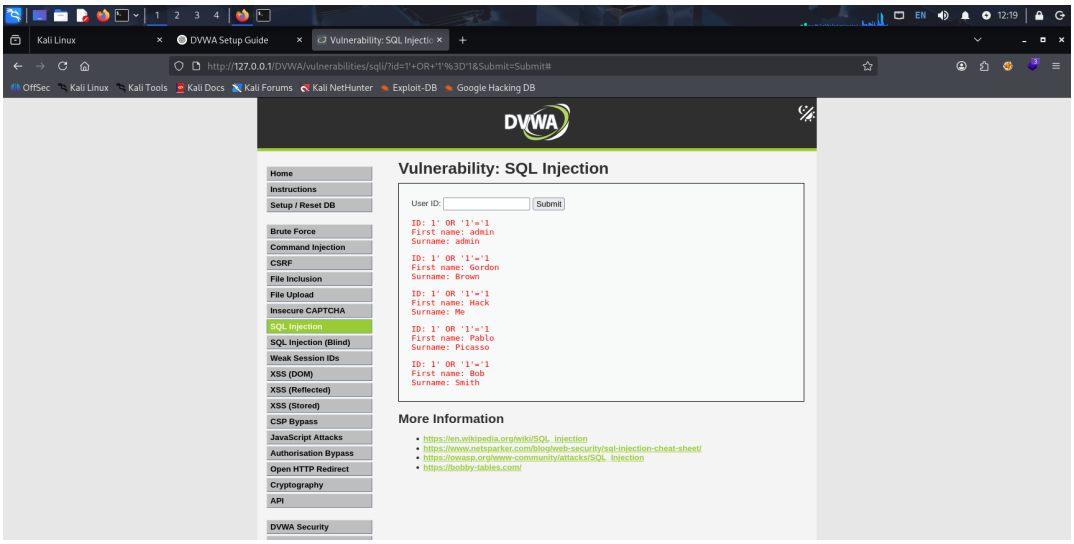
Proof of Concept

Step 1: Login to DVWA (127.0.0.1)



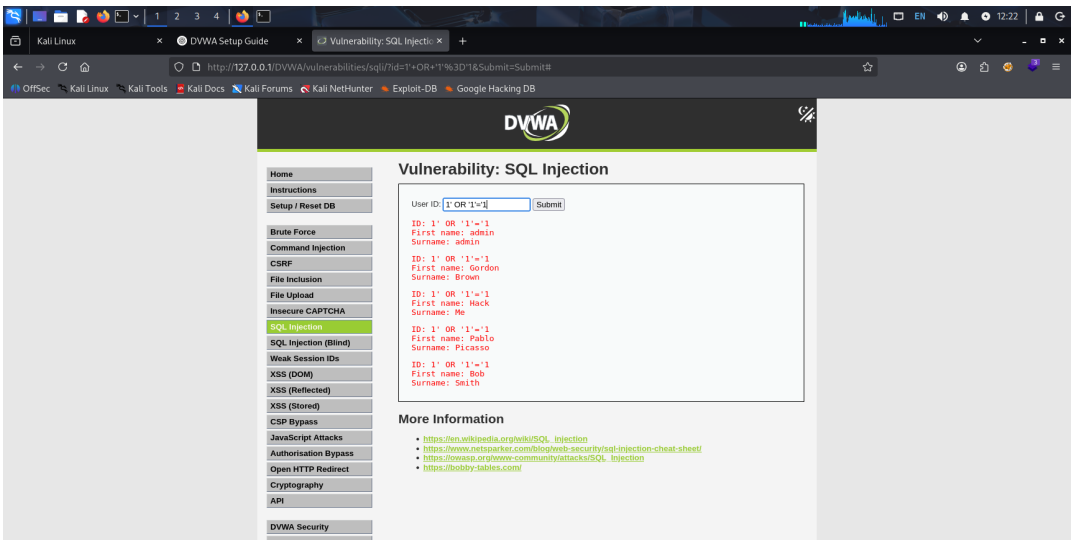
Step 2: Navigate to SQL Injection module

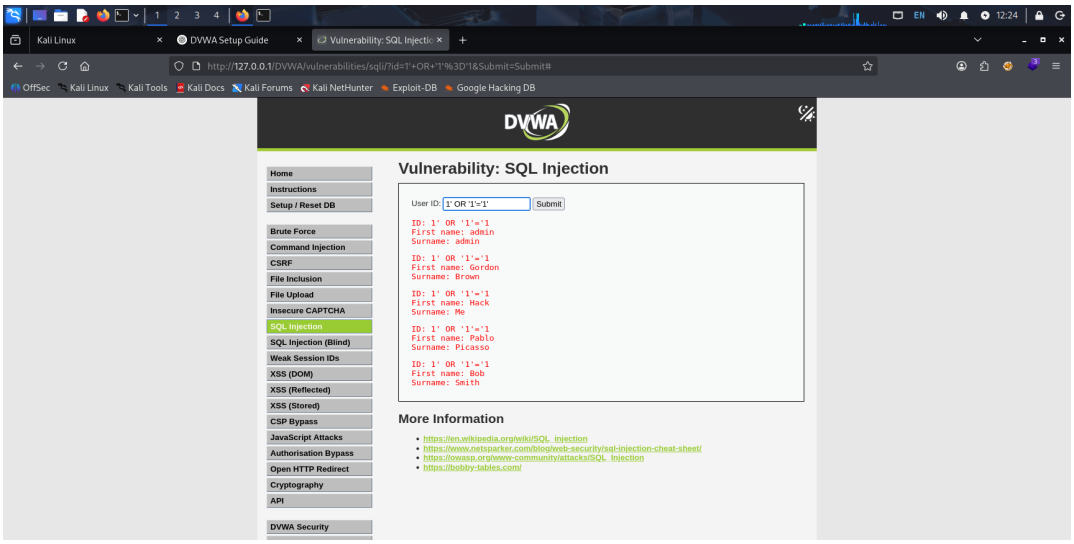
Step 3: Enter normal input: 1



Step 4: Inject payload: 1' OR '1'='1

Step 5: Output shows all users





Impact

This vulnerability allows unauthorized access to sensitive data, authentication bypass, and potential full database compromise.

Recommendations

1. Use prepared statements (parameterized queries) to prevent SQL injection.
2. Validate and sanitize all user inputs strictly.
3. Use allow-list validation (e.g., only numeric input for IDs).
4. Implement proper error handling to avoid leaking database information.
5. Apply Web Application Firewall (WAF) for additional protection.

Remediation

Developers should modify the backend code to use secure database interaction methods. Replace dynamic SQL queries with parameterized queries. Additionally, enforce strict input validation rules, limit database user privileges, and regularly perform security testing.

Conclusion

The SQL Injection vulnerability was successfully exploited to retrieve all user records, demonstrating the importance of secure coding practices.